



File No.: EXP202303035

RESOLUTION OF RECONSIDERATION APPEAL

Examined the reconsideration appeal filed by BANCO PICHINCHA ESPAÑA, S.A. (hereinafter, the appellant) against the resolution issued by the Director of the Spanish Agency for Data Protection dated October 1, 2024, and based on the following

FACTS

FIRST: Ms. A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on January 20, 2023. The complaint is directed against BANCO PICHINCHA ESPAÑA, S.A. with NIF A85882330 (hereinafter, BANK).

In the received document, the following is reported:

The claimant states that her phone number ***PHONE.1, of which she is the owner, was cloned by the company DIGI SPAIN TELECOM, S.L.U. ("DIGI"), since on September 4, 2021, without any security measures aimed at reliably identifying the person who requested it, a third party, impersonating the identity of the claimant, requested the cloning of the phone, with the purpose of making calls to the banking entity BANCO PICHINCHA ESPAÑA, S.A. and thus carrying out certain operations that resulted in a total of 50,000 euros transferred from her bank account to other accounts.

Along with the notification, a police report and complaints made are attached.

SECOND: In accordance with Article 65.4 of the LOPDGDD, the complaint was forwarded to DIGI for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on March 8, 2023, as evidenced by the acknowledgment of receipt in the file.

On April 5, 2023, this Agency received a response indicating that "...in accordance with what the Claimant indicated in the complaint filed with the AEPD, on September 7, 2021, due to her phone having problems, she requested from her telephone operator a copy of her SIM card, as well as a list of outgoing calls made from her phone number, verifying that three (3) calls had been made to the PIBANK Customer Service phone, which, according to the Claimant, had not been made by her.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Subsequently, as indicated by Ms. A.A.A., on September 28, 2021, she attempted to access PIBANK's Online Banking, discovering that her usual password generated an access error, which is why she contacted PIBANK's Customer Service through the contact number 911110000, in order to recover her Online Banking credentials.

When a customer requests the recovery of credentials for Online Banking at the Entity, the operator who answers the call must ask a series of security questions structured as identification defense mechanisms for customers, asking the customer questions whose answers would be easy for them to remember, but at the same time difficult for anyone else to guess. (...):

o

(...)

o

(...)

o

(...)

o

(...)

o
(...)
o
(...)
o
(...)
o
(...)
o
(...)
(...).
(...).

In relation to the above, it is noteworthy that, at the time of the events, the Bank had outsourced customer service to the entity GLOBAL SALES SOLUTIONS LINE, S.L., which was responsible, among other issues, for handling incoming calls to the Entity...”.

“...Despite the fact that, as evidenced, the Bank had reiterated on different occasions, and through various means, to its Provider what the procedure was for a customer to recover their Online Banking credentials, as well as the specific instructions regarding the modus operandi of the operators in situations where the customer does not respond accurately and clearly to the questions asked, in the call made by the GSS operator to Ms. A.A.A. on September 6, 2021, at 12:13 hours, said operator did not strictly comply with the protocol established by the Entity, since, (...), the operator continued to ask more questions to the Claimant, ultimately initiating the process of automatically sending the corresponding OTP code via SMS to the phone number that the Claimant provided to the Bank at the time of account opening (let us remember that this number was verified by the Claimant herself at the time of contracting, as has been stated above), which would allow her to change the password for Online Banking.

In this regard, it is of interest to the Entity to inform this Agency that, despite being a call that was later considered fraudulent, a fact of which the Bank became aware afterwards, through communications made by the Claimant days later, the Bank made available to the Provider all the necessary tools to comply

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/8

strictly in accordance with current regulations, and having detected no signs of irregularity that would lead it to distrust a possible fraudulent hiring. In this regard, the Bank considers that, if there is a breach, it would be attributable to GSS, since Article 28.10 of the GDPR establishes that: “if a processor infringes this Regulation by determining the purposes and means of processing, it shall be considered responsible for the processing in relation to that processing.”

In light of the above, and as has been evidenced, the Supplier failed to comply with the instructions provided by the Bank, thus acquiring the status of data controller in this case...

THIRD: On April 20, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the claimant was admitted for processing.

FOURTH: On October 2, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, for the alleged infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR.

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement of allegations in which it requests that it be considered presented along with the accompanying documents, that they be admitted, and having regard to the previous allegations, and after the appropriate procedures, it be agreed:

- The filing of the referenced file, rendering the initiated sanctioning procedure ineffective.

- In the event that the previous request is not accepted by the Agency, it requests that the mitigating circumstances presented be taken into account and, consequently, that the procedure be concluded with a warning.

- In the hypothetical case that none of the previous requests are accepted by the AEPD; as a last resort, it requests that the amounts established in the Agreement be reduced, taking into account the arguments expressed in the body of the written statement.

In its allegations, in summary, the respondent argues:

1.- In its first allegation, the BANK refers to the fact that it has had, at all times, sufficient and adequate legitimacy for the processing of the personal data of the claimant as a result of the formalization, management, and execution of the contractual relationship maintained by both parties. Regarding the impersonation, it considers that the Agency should attribute an infringement of Article 6 in relation to Article 7 of the GDPR to the one who obtained and used the claimant's data for illicit gain. The BANK also points out that it immediately proceeded to return the amounts taken, despite the judicial dismissal of the proceedings. Finally, it refers to various resolutions of dismissal by the Spanish Agency for Data Protection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/8

2.- In its second allegation, BANCO proceeds to analyze the disproportionality of the sanction, as well as the aggravating factors applied in the grading of the sanction, pointing out the following mitigating factors for the purpose of reducing the administrative sanction:

- That the entity, acting in good faith, diligence, and proactivity, effectively resolved the incident that was the subject of the complaint.

- The absence of facilitation of the personal data of the complainant to a third party along with the procedures instituted by the company.

- The non-existence of alleged prior infringements.

- The high degree of cooperation in order to offer and make available to this agency all information that was at its disposal.

- That the entity never provided any personal data to the identity thief.

- That the entity has never obtained any type of benefit.

Finally, it notes that the measures in force at the time of the events complied with the most rigorous standards to address risks and were adequate and suitable considering the state of the art, the costs of application, the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of individuals.

However, the allegations presented were dismissed.

SIXTH: On August 8, 2024, a resolution proposal was made, proposing to sanction BANCO PICHINCHA ESPAÑA, S.A., with NIF A85882330, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, with a fine of €50,000 (FIFTY THOUSAND EUROS).

SEVENTH: Once the resolution proposal was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement of allegations on August 21, 2024.

In its allegations, in summary, the respondent states:

1. In its first allegation, BANCO insists that it has always processed the personal data of Ms. A.A.A. (hereinafter, interchangeably, the "Complainant") on an adequate legal basis in accordance with the provisions of Article 6 of the GDPR and points out that the one who processed the data without sufficient legitimacy and, therefore, who should have obtained the consent of the Complainant for its proper processing was the impersonator, with the AEPD making an error as stated in the Resolution Proposal.

Finally, in this same allegation, it refers to the fact that the AEPD has not followed the same criterion as the Investigating Court (...) regarding the dismissal, as well as the principle of certainty and the principle of in dubio pro reo.

1. In its second allegation, BANCO insists on the absence of any type of responsibility for the actions

taken by GSS, as the data processor.

2. In its third allegation, BANCO refers to jurisprudence that has determined that an action cannot be sanctioned without a certain degree of intent, as well as that the existence of a culpable infringement constitutes a requirement for the imposition of a fine.

3. Finally, BANCO alleges the principle of proportionality, stating that the proposed sanction is not appropriate and, in the hypothetical case that it were appropriate, it would not be proportional to the factual situation at hand.

It concludes its written allegations by stating that it attaches two payment receipts made in favor of the AEPD, of €40,000 and €10,000 respectively, and the reasons for making such payments. It is emphatic that these are not an acknowledgment of the alleged facts, but rather that the intention is to avoid possible future accruals of interest.

EIGHTH: On October 1, a resolution was issued by the Director of the Spanish Agency for Data Protection imposing on BANCO PICHINCHA ESPAÑA, S.A., with NIF A85882330, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, a fine of €50,000 (FIFTY THOUSAND EUROS).

NINTH: Once the aforementioned resolution was notified in accordance with the rules established in the LPACAP, the respondent submitted a request for reconsideration within the legally established timeframe, in which, in summary, it states that:

- In its first allegation, it insists that there has been no breach by BANCO PICHINCHA of the provisions of Article 6.1 of the GDPR, with the absence of lack of legitimacy falling on the third party who allegedly impersonated the data subject.

- In its second allegation, BANCO PICHINCHA again argues that it gave clear instructions to GSS on how to proceed with the processing of personal data regarding the service provided by it and as the data processor itself acknowledged the alleged facts, the responsibility cannot be attributed to BANCO PICHINCHA.

- In its third allegation, it refers to an error in the evaluation of the evidence by this AEPD.

- In its final allegation, it insists on the previously alleged violation of the principle of proportionality, limiting this agency to conveying the literal wording of what is stated in its resolution regarding the provisions of Articles 83.4 and 83.5 of the GDPR, omitting any motivation in observing the principle of proportionality.

LEGAL GROUNDS

I

Competence

The Presidency of the Spanish Agency for Data Protection is competent to resolve this appeal, in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/8

II

Grounds of the contested resolution

In relation to the statements made in the appeal, which basically reiterate those already made during the processing of the present file, it should be noted that they have already been analyzed and dismissed in the contested resolution, whose grounds remain fully valid.

In the present case, there are various calls to the banking entity BANCO to carry out certain operations, following a change of credentials, which resulted in a total of 50,000 euros transferred from the claimant's bank account to other accounts.

The operations carried out were not conducted within the scope of the BANCO-client contractual relationship since they were performed by a third party without the client's consent and without BANCO

adequately verifying the identity of its interlocutor, which has led to the conclusion that there has been processing of the claimant's personal data without legitimacy.

It is evident that, both in the procedure for a client to recover their Online Banking credentials and in the specific instructions regarding the *modus operandi* of the operators in situations where the client does not respond accurately and clearly to the questions asked (the supposed client indicated in the call that they were unaware of the balance in their bank account, showing doubts in response to what their profession was...), did not prevent the initiation, ultimately, of the automatic process of sending the corresponding OTP code via SMS to the phone number, allowing the change of the Online Banking password and the subsequent financial operations already mentioned.

It is recorded in the file, and the responding party states that in the call made by the GSS operator to the claimant on September 6, the operator did not strictly comply with the protocol established by BANCO, since "the supposed client" indicated in the call that they were unaware of the balance in their bank account, as well as doubts about their profession.

Moreover, BANCO acknowledges the error by transferring responsibility to the Provider for failing to comply with the instructions provided by it.

"...Although, as has been evidenced, the Bank had reiterated on different occasions, and by various means, to its Provider what the procedure was for a client to recover their Online Banking credentials, as well as the specific instructions regarding the *modus operandi* of the operators in situations where the client does not respond accurately and clearly to the questions asked, in the call made by the GSS operator to Ms. A.A.A. on September 6, 2021, at 12:13 hours, said operator did not strictly comply with the protocol established by the Entity, since, despite the supposed client indicating in the call that they were unaware of the balance in their bank account, showing doubts in response to what their profession was, the operator continued to ask more questions to the Claimant, ultimately initiating the process.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/8

of automatic sending of the corresponding OTP code via SMS to the phone number that the Complainant provided to the Bank at the time of account opening (let us remember that this number was verified by the Complainant herself at the time of contracting, as previously stated), which would allow her to change the password for Online Banking.

In this regard, it is of interest to the Entity to inform this Agency that, despite the fact that it was a call that was later considered fraudulent, a fact that the Bank became aware of later through communications made by the Complainant days afterward, the Bank made all necessary tools available to the Provider to strictly comply with current regulations, and having detected no signs of irregularity that would lead it to distrust a possible fraudulent contracting. In this sense, the Bank considers that, if there were a breach, it would be attributable to GSS, since Article 28.10 of the GDPR establishes that: "if a processor infringes this Regulation by determining the purposes and means of processing, it shall be considered responsible for the processing in relation to that processing."

In light of the above, and as has been evidenced, the Provider failed to comply with the instructions provided by the Bank, thus acquiring the status of data controller in this case...

Although it is the data controller who must apply appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with the Regulation.

Ultimate responsibility for the processing remains with the controller, who determines the existence of the processing and its purpose, and not with the processor.

III

Conclusion

Therefore, given that, in the present appeal for reconsideration, no new facts or legal arguments have been presented that would allow for a reconsideration of the validity of the contested resolution, and that the purpose of the appeal is to review the legality of the administrative action, it is appropriate to agree to its dismissal, without prejudice to the fact that the appealing party may file a new claim

providing copies of all relevant documents in their possession, in relation to a possible infringement within the Agency's jurisdiction.

VI

Late Resolution

Due to reasons related to the functioning of the administrative body, therefore not attributable to the appealing party, as of this date, the mandatory pronouncement of this Agency regarding the present appeal has not been issued.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/8

In accordance with the provisions of Article 24 of the LPACAP, the meaning of administrative silence in the procedures for challenging acts and provisions is dismissive.

Nevertheless, and despite the time elapsed, the Administration is obliged to issue an express resolution and to notify it in all procedures regardless of their initiation form, as provided in Article 21.1 of the aforementioned LPACAP.

In cases of dismissal by administrative silence, the express resolution after the expiration of the term will be adopted by the Administration without any binding connection to the meaning of the silence, as provided in Article 24.3 of the same law.

Therefore, it is appropriate to issue the resolution that concludes the procedure of the appeal for reconsideration filed.

Having reviewed the cited provisions and others of general application, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by BANCO PICHINCHA ESPAÑA, S.A. against the Resolution of this Spanish Agency for Data Protection issued on October 1, 2024, imposing on BANCO PICHINCHA ESPAÑA, S.A., with NIF A85882330, a fine of €50,000 (FIFTY THOUSAND EUROS) for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR.

SECOND: NOTIFY this resolution to BANCO PICHINCHA ESPAÑA, S.A. Against this resolution, which concludes the administrative procedure, an administrative contentious appeal may be filed within two months from the day following the notification of this act, as provided in Article 46.1 of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of the aforementioned legal text.

1245-21112023

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 of the LOPDGDD, due to vacancy in the position of Presidency and Deputy Presidency.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es